

MODULE 12 · DOMAIN 3 - AI SAFETY, SECURITY, AND GOVERNANCE

Locking It Down

Task 3.2. VPC endpoints, IAM condition keys, KMS, PII handling, data residency and the right to erasure.

DOMAIN 3 of 5 EXAM WEIGHT 20% MODULE 12 of 22

One model invocation passes through **five separate places you can say no**. Knowing which one a question is asking about is most of the skill.

One invocation, five places to stop it

01

SCP

Organisation-wide boundary. Nobody can grant past it.

02

IAM policy

What this role may do, on which models.

03

Endpoint policy

What may travel this private network path.

04

Guardrail

What content may pass in or out.

05

Logging

CloudTrail for the call, invocation logging for the content.

ON THE EXAM

The last one is not a control. It records. Confusing detection with prevention is the commonest error in this whole domain, and module 10 saw it twice.

What Bedrock already does for you

- ◆ **Your data is not used to train base models**, and is not shared with model providers.
- ◆ **Bedrock does not store your prompts or completions** for inference by default. You opt into logging.
- ◆ **Data stays in your Region**, subject to the cross-Region inference rules from module 1.
- ◆ **TLS in transit** always, and **encryption at rest** with AWS-owned KMS keys by default.
- ◆ Bedrock is **HIPAA-eligible**, SOC 2 compliant and supports PCI DSS workloads.

ON THE EXAM

Questions sometimes propose elaborate architectures to achieve something Bedrock already guarantees. Knowing the defaults is what lets you eliminate those options quickly.

Getting Bedrock off the public internet

- ◆ **Four interface endpoints:** *bedrock*, *bedrock-runtime*, *bedrock-agent*, *bedrock-agent-runtime*.
- ◆ Control plane and runtime are **separate**. Managing models and calling them differ.
- ◆ A knowledge base workload needs **four to six**, adding **S3 gateway** and **KMS**.
- ◆ The S3 gateway endpoint is free. Interface endpoints bill per hour, per AZ.
- ◆ Across three AZs and many VPCs that adds up. A shared hub VPC is the usual answer.

ON THE EXAM

"No internet gateway, no NAT" means interface endpoints. If a knowledge base reads from S3, remember the gateway endpoint for the data path.

Network path or endpoint policy?

THE VPC ENDPOINT

Where traffic can go

- Private path, no internet gateway or NAT
- Traffic never traverses the public internet
- A network control
- Says nothing about who or what

THE ENDPOINT POLICY

What may use that path

- A resource policy attached to the endpoint
- Restrict principals, actions and model ARNs
- An authorisation control
- Enforced even if IAM would allow it

THE TIEBREAKER

Creating an endpoint privatises the path. Attaching a policy is what stops any principal in the VPC using it to reach any model. Scenarios often need both.

A bank runs its AI application on Amazon ECS in private subnets with no internet gateway and no NAT gateway. The application must call Amazon Bedrock and query a Bedrock knowledge base whose source documents are in Amazon S3.

Security requires that no traffic reaches the public internet, and that even a compromised container in this VPC cannot invoke models other than the two the application is approved to use.

What should the bank configure?

- ☐ A Interface endpoints for bedrock-runtime and bedrock-agent-runtime, an S3 gateway endpoint, and endpoint policies restricting invocation to the two approved model ARNs
- ☐ B A NAT gateway with a restrictive security group allowing only Bedrock endpoints
- ☐ C Interface endpoints for the Bedrock services, relying on the task role's IAM policy to restrict which models can be invoked
- ☐ D An AWS Direct Connect circuit to keep Bedrock traffic off the internet

What should the bank configure?

- A

 Interface endpoints, S3 gateway, plus endpoint policies
Covers the runtime path, the agent runtime path for the knowledge base, the S3 data path, and pins the approved models at the network boundary.
- B

 NAT gateway with a security group
A NAT gateway is a route to the public internet, which the requirement forbids outright. Security groups filter addresses, not model ARNs.
- C

 Endpoints, IAM only
The task role's policy is the right idea in the wrong place. A compromised container runs as that role, so it inherits whatever the role may do.
- D

 Direct Connect
Connects a data centre to a Region. It does nothing for compute already inside a VPC needing to reach an AWS service.

THE SIGNAL

"Even a compromised container" is the phrase. It assumes the caller's own credentials are in enemy hands, which is exactly the case an endpoint policy covers and an identity policy does not.

Customer managed keys, and where they apply

- ◆ Default encryption uses **AWS-owned keys**. A CMK gives you key rotation, revocation and an audit trail of key use.
- ◆ CMKs apply to **custom models, knowledge bases, agents, guardrails, Automated Reasoning policies** and invocation logs.
- ◆ **Revoking the key revokes access to the data.** That is often the actual reason a regulator asks for a CMK.
- ◆ **Cross-account use needs two grants:** the resource policy *and* *kms:Decrypt* in the key policy.
- ◆ Missing the second produces an access denial that only appears outside the owning account.

ON THE EXAM

That last pair is a real diagnostic. A KMS-sourced denial in CloudTrail points at the key policy; a Bedrock-sourced denial with IAM confirmed correct points at the resource policy.

A central security account owns a guardrail encrypted with a customer managed KMS key, shared with eleven workload accounts. The guardrail's resource policy allows the organisation. Applications in the security account use it successfully.

Applications in every workload account fail at inference time with an access denied error. IAM identity policies in those accounts have been reviewed and correctly permit both the Bedrock action and the guardrail ARN.

What is the most likely cause?

- ☐ A The guardrail resource policy is missing the workload accounts, despite allowing the organisation
- ☐ B The KMS key policy does not grant kms:Decrypt to the workload account principals, so they can reference the guardrail but cannot decrypt it
- ☐ C The workload accounts are missing a VPC endpoint for bedrock-runtime
- ☐ D An SCP is denying bedrock:ApplyGuardrail in the workload accounts

◆ PAUSE AND DECIDE

What is the most likely cause?

- A

 Resource policy missing the accounts
The scenario states the resource policy allows the organisation, which covers all eleven. The first of the two required grants is already in place.
- B

 KMS key policy missing kms:Decrypt
An encrypted guardrail needs both grants. The security account works because it owns the key; every other account can reference the guardrail and cannot decrypt it.
- C

 Missing VPC endpoint
That produces a connectivity failure or timeout, not an access denied error, and it would not spare the security account.
- D

 SCP denying ApplyGuardrail
Possible in principle, and it would not explain why the pattern follows key ownership so exactly. It is also not what the evidence points to.

THE SIGNAL

"Works in the owning account, fails everywhere else" is the signature of a key policy gap. The owner has implicit key access; nobody else does until the key policy says so.

The condition keys worth knowing

- ◆ **bedrock:InferenceProfileArn** pins which inference profiles a role may use. This is how residency is enforced.
- ◆ **bedrock:GuardrailIdentifier** requires a specific guardrail on the call, making safety non-optional.
- ◆ **aws:RequestedRegion** restricts which Regions the API may be called in at all.
- ◆ Grant on **specific model ARNs**, and remember streaming is a separate action from `InvokeModel`.
- ◆ Combine them: this role, these models, through this profile, with this guardrail, in these Regions.

ON THE EXAM

That last line is the shape of a production Bedrock policy. Each clause maps to one requirement a scenario is likely to state, so read the requirements and assemble the policy.

Identity policy or service control policy?

IAM IDENTITY POLICY

What this role may do

- Attached to a role or user
- Grants and denies permissions
- Owned by the account team
- An account admin can change it

SERVICE CONTROL POLICY

The ceiling nobody can raise

- Attached to an OU or account
- Only restricts. It never grants
- Owned by the organisation
- An account admin cannot override it

THE TIEBREAKER

"Must apply across all accounts" or "a team must not be able to change it" means SCP.
"This application needs access to X" means an identity policy.

There are four services that handle personal data, and they act at **four different moments**. Choosing correctly is choosing the moment, not the service.

Where each PII control acts

SERVICE	WHEN IT ACTS	WHAT IT GIVES YOU
Amazon Macie	On data at rest in S3	Discovery and classification. It reports
Amazon Comprehend	During pipeline processing	Entity types and character offsets
Comprehend Medical	During pipeline processing	PHI entity types, clinically aware
Bedrock Guardrails	At model invocation	Block or mask, on prompt and response
Your own Lambda	Wherever you place it	Any rule you can write

ON THE EXAM

Macie finds sensitive data you did not know you had; it does not redact a prompt. For clinical text, Comprehend Medical detects PHI that general PII detection misses.

A retailer discovered that a shared S3 bucket used as a knowledge base source contained several spreadsheets of customer records that nobody knew were there. They had already been ingested and were being retrieved in answers.

The team must find any other sensitive data across 340 buckets, prevent unknown sensitive files from being ingested in future, and ensure that any personal data that does reach a prompt is masked rather than blocking the request.

Which combination addresses all three requirements?

- ☐ A Amazon Macie to scan and classify the buckets, a Comprehend-based validation step in the ingestion pipeline, and Bedrock guardrail sensitive information filters set to ANONYMIZE
- ☐ B Bedrock guardrail sensitive information filters set to BLOCK, applied to every request
- ☐ C Amazon Macie to scan the buckets, and rely on its findings to remove sensitive files manually
- ☐ D A Lambda function scanning every document at ingestion using regular expressions for common PII formats

Which combination addresses all three requirements?

- A** Macie, Comprehend in the pipeline, guardrail ANONYMIZE

One control per requirement, each at the right moment: discovery at rest, prevention at ingestion, masking at invocation.
- B** Guardrail filters set to BLOCK

Acts only at invocation, so it finds nothing across 340 buckets and prevents no ingestion. It also blocks when the requirement says mask.
- C** Macie plus manual removal

Answers the discovery requirement well and leaves the other two entirely unaddressed. Manual removal does not prevent the next unknown file.
- D** Lambda with regular expressions

Covers ingestion only, and regular expressions miss names and addresses that have no fixed format. Comprehend is trained for exactly that.

THE SIGNAL

Three requirements at three different moments. This scenario exists to test whether you place controls by moment rather than reaching for the one service you know best.

Governance over the data itself

- ◆ **AWS Glue Data Catalog** holds the metadata: what data exists, where, in what shape, classified how.
- ◆ **AWS Lake Formation** enforces fine-grained access on that catalogue, down to table, column and row.
- ◆ That matters for GenAI because it governs **what a pipeline may read** before anything is ever embedded.
- ◆ **Lineage** answers the question every audit asks: which source produced this chunk, and this answer?
- ◆ Tag classification at ingestion, and the tag becomes retrieval metadata as module 4 described.

ON THE EXAM

Lake Formation is upstream of everything in this course. If a pipeline may not read a column, that column never becomes a chunk and never appears in an answer.

A right-to-erasure request is a completeness problem. Deleting the source document is the **easy part**, and it is not the part that fails an audit.

What a deletion request actually has to reach

- ◆ **The source document**, in S3 or the originating system. The obvious one.
- ◆ **The chunks and embeddings** in the vector store. Module 4 showed deletions must propagate, or stale chunks are still retrieved.
- ◆ **Model invocation logs**, if enabled. Prompts and completions are stored content.
- ◆ **Conversation history** in DynamoDB, which is why a TTL on those records is a privacy control as well as a cost one.
- ◆ **Caches and backups**. Prompt caches expire on their own; backups do not.

ON THE EXAM

The embedding is the copy people forget. It is derived from the text, lives in a different store, and is not removed by deleting the document it came from.

Retention, consent and evidence

- ◆ **Retention.** S3 lifecycle rules, DynamoDB TTL and log retention settings, applied deliberately rather than by default.
- ◆ **Consent.** Record it as metadata, and make it a retrieval filter so withdrawn consent removes content from answers.
- ◆ **Audit trails.** CloudTrail for the API call, model invocation logging for the content. You usually need both.
- ◆ **Evidence of deletion** matters as much as deletion. Log what was removed, from where, and when.
- ◆ Enabling invocation logging creates a privacy obligation you did not have before. Decide retention at the same time.

ON THE EXAM

Consent as a retrieval filter is the elegant version: withdrawn consent flips a metadata attribute and the content stops appearing, without re-ingesting anything.

A European employer receives an erasure request from a former employee. Their data appears in HR documents indexed in a Bedrock knowledge base, in six months of assistant conversation history in DynamoDB, and in model invocation logs written to S3.

The team has deleted the HR documents from the source S3 bucket and considers the request fulfilled. Legal has asked for evidence that the person's data can no longer appear in any assistant answer.

What still needs to be done?

- ☐ A Nothing further. Deleting the source documents removes them from the knowledge base automatically
- ☐ B Run an ingestion sync so deletions propagate to the vector index, delete the relevant conversation history and invocation log records, verify with a retrieval test, and log the evidence
- ☐ C Delete and rebuild the entire knowledge base from the current source documents
- ☐ D Add a metadata filter excluding the former employee from retrieval results

◆ PAUSE AND DECIDE

What still needs to be done?

A Nothing further

Deleting a source object does not remove its chunks from the vector index until a sync runs, and it never touches DynamoDB or the S3 logs.

C Delete and rebuild the knowledge base

Would clear the index by brute force, at significant cost, and still leaves conversation history and invocation logs untouched.

B Sync, delete the other copies, verify, log the evidence

Reaches all three stores the scenario names, and the retrieval test plus the record are what satisfy legal's actual request.

D Metadata filter excluding them

Hides the data from retrieval while retaining it. Erasure means deletion, and a filter is a configuration somebody can remove.

THE SIGNAL

The scenario lists three stores in its first sentence and the team addressed one. Erasure questions are completeness questions, so count the copies before you count the options.

Cross-border data flow, enforced

- ◆ **Regional deployment** is the starting point, but it is a convention until something enforces it.
- ◆ **Geographic inference profiles** bound where inference runs, as module 1 established.
- ◆ **SCPs with `aws:RequestedRegion` and `bedrock:InferenceProfileArn`** are what make that boundary unbreakable.
- ◆ Remember what stays behind: **logs, knowledge bases and configuration remain in the source Region.**
- ◆ A global inference profile is faster and cheaper, and wrong wherever a regulator is mentioned.

ON THE EXAM

This skill is module 1 seen from the security side. There the question was capacity; here it is enforcement. The same two mechanisms answer both.

A multinational must guarantee that EU customer data is only ever processed by models running in EU Regions. Applications currently use EU geographic inference profiles by convention, documented in an architecture standard.

An internal audit found one team using a global inference profile in a test account, having copied a code sample. The organisation wants a control that makes this impossible rather than detectable, applied across all sixty accounts, that a local account administrator cannot remove.

What should the organisation implement?

- ☐ A An IAM policy in each account denying invocation on non-EU inference profile ARNs
- ☐ B A service control policy denying `bedrock:InvokeModel` unless `bedrock:InferenceProfileArn` matches EU profiles, applied at the organisation root
- ☐ C AWS Config rules detecting use of global inference profiles, with automatic remediation
- ☐ D CloudTrail alerts on invocations using non-EU inference profiles

What should the organisation implement?

A IAM policy in each account

Correct mechanism at the wrong altitude. Sixty policies to maintain, and any account administrator can edit their own.

C Config rules with remediation

Detects after the fact and remediates after that. The data has already been processed outside the EU by the time remediation runs.

B SCP on InferenceProfileArn at the organisation root

One policy, every account, and no account administrator can grant past it. The condition key makes the rule specific rather than blanket.

D CloudTrail alerts

Pure detection, which is what the audit already achieved. The requirement explicitly asks for impossible rather than detectable.

THE SIGNAL

"Impossible rather than detectable" and "a local administrator cannot remove" are two separate clauses that both point at an SCP. Nothing else in AWS satisfies the second.

The five things to carry forward

- ◆ **Five control points.** SCP, IAM policy, endpoint policy, guardrail, logging. Logging is not a control.
- ◆ **The endpoint gives a private path; the endpoint policy says who may use it.** "Even if compromised" means the second.
- ◆ **Cross-account CMK needs two grants:** the resource policy and kms:Decrypt. Works in the owner account only is the signature.
- ◆ **PII: choose the moment.** Macie at rest, Comprehend in the pipeline, guardrails at invocation.
- ◆ **Erasure is a completeness problem.** Source, embeddings, logs, conversation history, caches and backups.

ON THE EXAM

Module 13 closes Domain 3 with governance and responsible AI: audit, lineage, citations, model cards, bias and drift.